

クロスサイト スクリプティング (XSS)

Webアプリケーションの脆弱性とセキュリティ対策



XSS (Cross-Site Scripting) とは？

基本定義

XSSは、攻撃者がWebサイトに**悪意のあるスクリプト**を注入するサイバー攻撃の一種です。ユーザーのブラウザ上で不正なスクリプトが実行されることで被害が発生します。

なぜ起こるのか？

Webアプリケーションが、外部からの入力（ユーザーの投稿など）を適切に処理・無害化せずに、そのままブラウザに表示してしまう脆弱性が原因です。

"ユーザーの入力を信頼しすぎる"ことが最大の問題です。

攻撃の仕組み

1. 注入 (Injection):

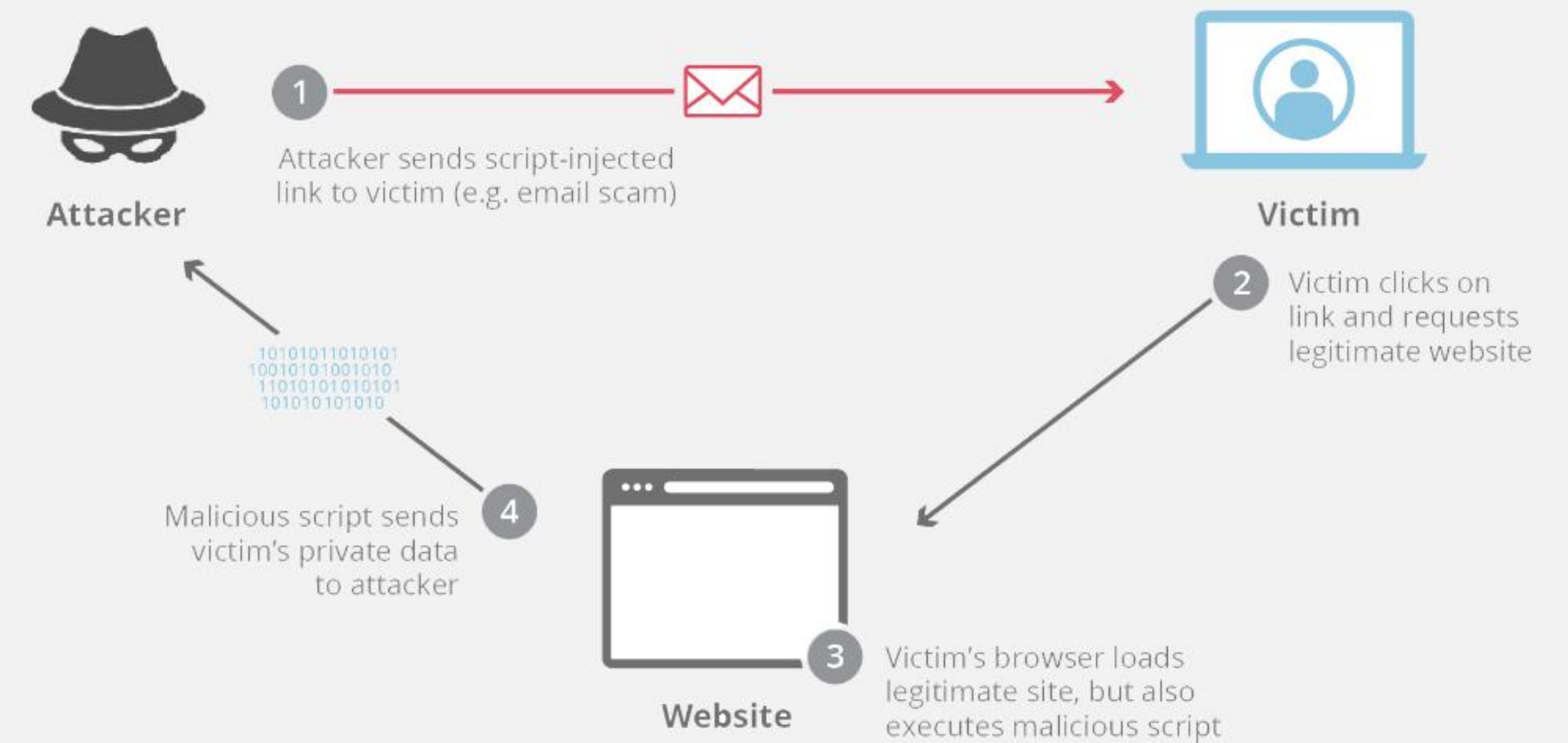
攻撃者が脆弱性のあるサイトに悪意あるスクリプト（JavaScript等）を送り込みます。

2. 配信 (Delivery):

サーバーはそのスクリプトを含んだページを、何も知らない被害者に送信します。

3. 実行 (Execution):

被害者のブラウザは、正規のサイトからのコードと信じてスクリプトを実行してしまいます。



1. 反射型 XSS (Reflected XSS)

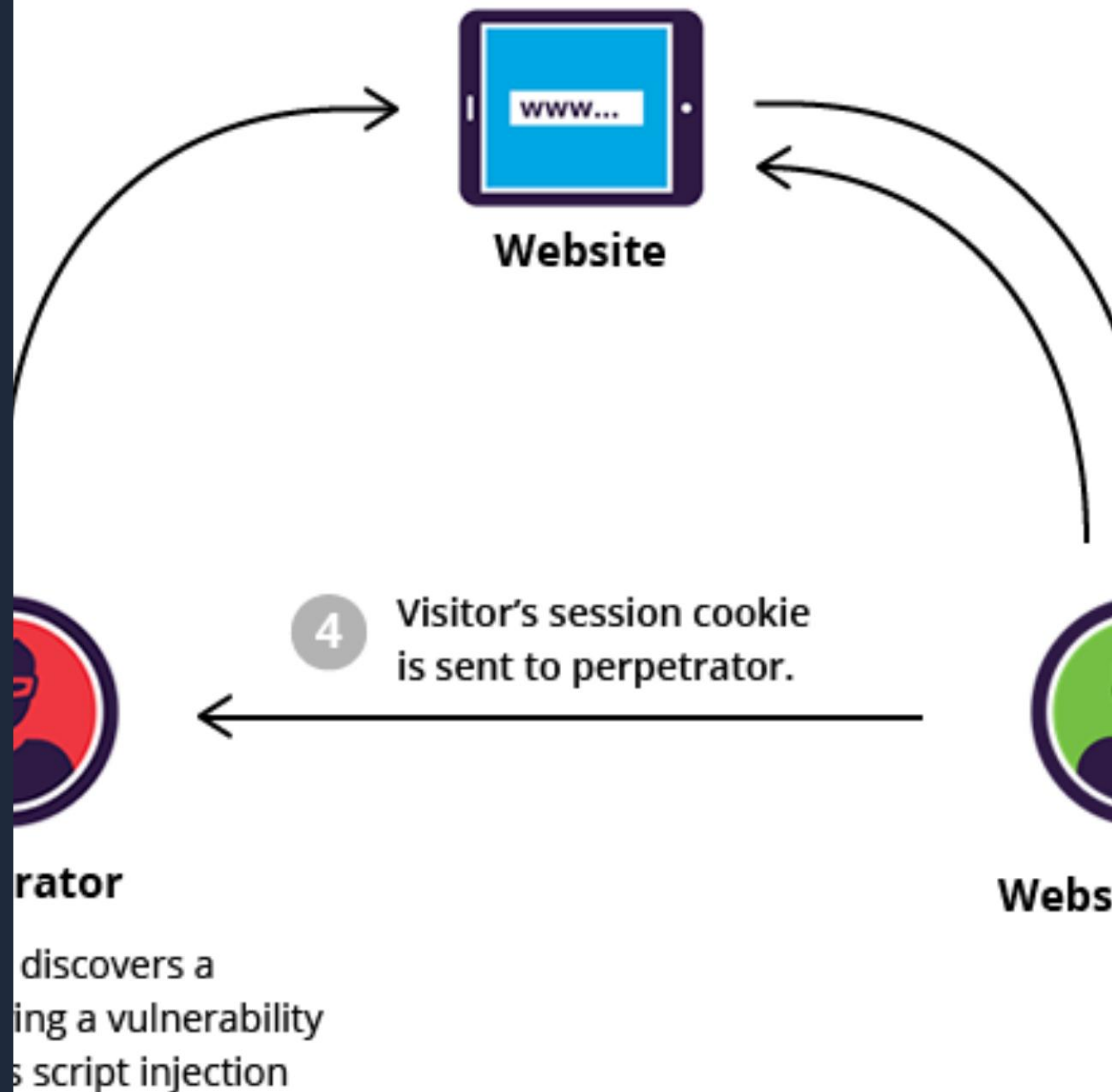
リクエストに含まれた悪意あるスクリプトが、サーバーからのレスポンスとして即座に「反射」されて実行されるタイプです。

攻撃者は、スクリプトを含んだ**不正なリンク**をメールやSNSで被害者にクリックさせる手法をよく使います。

2. 蓄積型 XSS (Stored XSS)

悪意あるスクリプトがサーバーのデータベース等に保存されるタイプです。

掲示板やコメント欄への投稿が典型的です。そのページを閲覧した**すべてのユーザー**が被害に遭うため、非常に危険度が高い攻撃です。



3. DOMベース XSS



クライアント側のみ

サーバーを介さず、ブラウザ上のJavaScriptだけで攻撃が完結します。



Source (入力点)

URLの一部 (location.hash) や入力フォームなどのデータを読み取ります。



Sink (実行点)

`innerHTML` や `eval()` などに不正なデータを書き込むことで発火します。

XSS攻撃の影響とリスク



セッションハイジャック

`document.cookie` を盗み出し、ユーザーになりすまして不正操作を行います。



フィッシング詐欺

偽のログインフォームを表示させ、パスワードなどの重要情報を入力させます。



マルウェア感染

ユーザーを悪意あるサイトへリダイレクトし、ウイルスやマルウェアをダウンロードさせます。

対策1: 入力値検証 (Input Validation)

入り口で防ぐ

サーバーがデータを受け取った時点で、想定された形式かどうかをチェックします。

- 郵便番号なら数字のみ
- URLならhttpから始まる

ホワइटリスト方式

「悪い文字を弾く」のではなく、「許可する文字以外はすべて拒否する」方式が安全です。

❗ ただし、これだけでは不十分な場合が多いため、次の出力対策が必須です。

対策2: 出力エンコーディング (重要)

無害化して表示する

ブラウザがコードとして解釈してしまう特殊文字を、ただの「文字」として変換します。

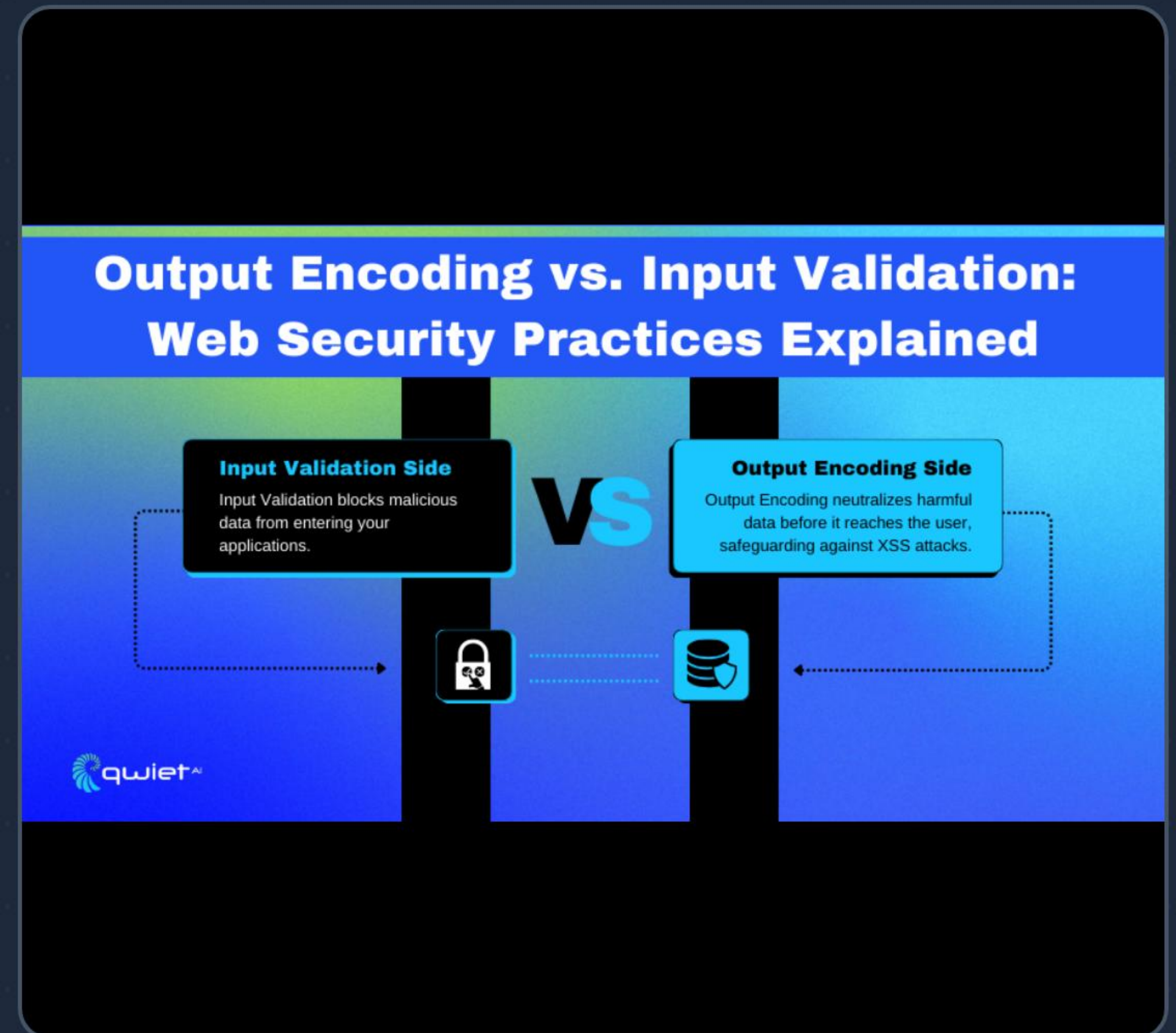
変換例 (HTMLエスケープ):

`alert(1)`



`<script>alert(1)</script>`

※HTML, JavaScript, CSSなど、出力する場所 (コンテキスト) に応じた適切なエスケープが必要です。



対策3: Content Security Policy (CSP)

ブラウザへの指示書

サーバーからHTTPヘッダーで「どのソースのスク립トなら実行して良いか」をブラウザに伝えます。

効果

万が一XSSの脆弱性があっても、CSP設定で「自ドメイン以外のスク립ト禁止」「インラインスク립ト禁止」としておけば、攻撃コードの実行を阻止できます。

```
Content-Security-Policy: default-  
src 'self';
```


まとめ: 安全なWeb開発のために

- ✓ ユーザー入力は決して信頼しない: 全ての外部データは悪意がある可能性があるとして想定する。
- ✓ コンテキストに応じたエスケープ: 表示する場所に合わせて適切に無害化を行う (最も基本的かつ重要)。
- ✓ 最新のフレームワークを利用する: React, Vue, Angularなどはデフォルトでエスケープ機能を持っているため、積極的に活用する。
- ✓ 多層防御 (Defense in Depth): WAFの導入やCSPの設定など、複数の対策を組み合わせる。



Q & A

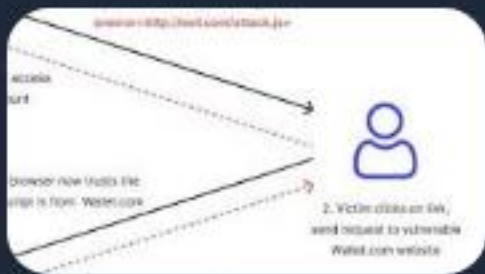
ご清聴ありがとうございました。
ご質問があればお気軽にどうぞ。

Image Sources



<https://www.cloudflare.com/img/learning/security/threats/cross-site-scripting/xss-attack.png>

Source: www.cloudflare.com



https://cdn.prod.website-files.com/5ff66329429d880392f6cba2/67b43112f8dcd7b19cfab500_62a206918d83fac965263459_Reflected%2520XSS%2520attack%2520in%2520action.jpeg

Source: www.wallarm.com



<https://www.imperva.com/learn/wp-content/uploads/sites/13/2019/01/sorted-XSS.png>

Source: www.imperva.com



https://qwiet.ai/wp-content/uploads/2024/04/1.-Output-Encoding-vs.-Input-Validation_-Web-Security-Practices-Explained.png

Source: qwiet.ai